



Data Agency and
Security (DAS) Lab



GEORGE MASON
UNIVERSITY®

Towards a Risk-Cost Model for Financial Adaptive Authentication

Supriya Khadka, **Sanchari Das**

Department of Information Sciences and Technology
George Mason University



[Read Full Paper Here](#)

The Stakes in Financial Authentication

In most systems, a wrong authentication decision is an inconvenience.

In financial and cryptocurrency systems, it is a direct monetary loss

Transactions in these systems are inherently liquid and irreversible.

Once funds move, there is no recovery mechanism; no chargeback, no rollback.

Persistent credential theft, replay attacks, and account takeover

They are documented drivers of loss in crypto ecosystems and financial platforms

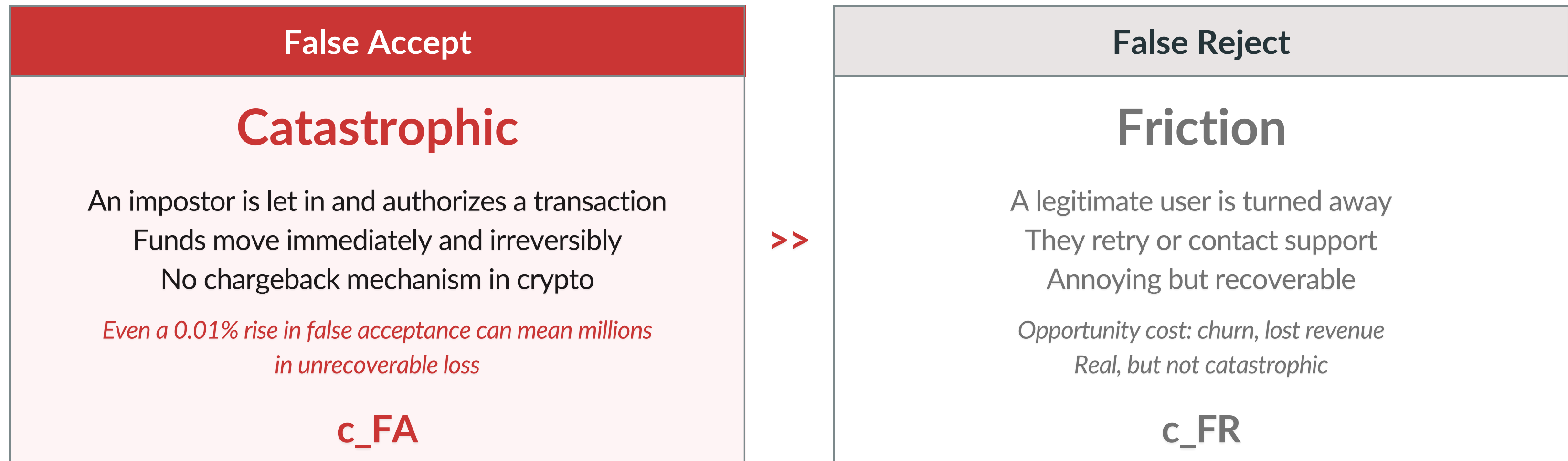
Even a marginal increase in false acceptance translates to outsized financial damage

Not proportional damage, but catastrophic damage

This is what makes financial authentication categorically different, and why it demands its own model.

The Asymmetry at the Heart of the Problem

Every authentication system makes two kinds of mistakes. In finance, they are not equal.



The Asymmetry at the Heart of the Problem

Existing systems treat these errors as equivalent, tuning FAR and FRR symmetrically. In finance, that is the wrong objective. The costs are not symmetric. The model must reflect that

This asymmetry is what our Risk-Cost Model formalizes.

Reframing as a Decision Problem

Rather than asking whether a user passes a threshold, the RCM asks:

what is the least costly action given what we know?

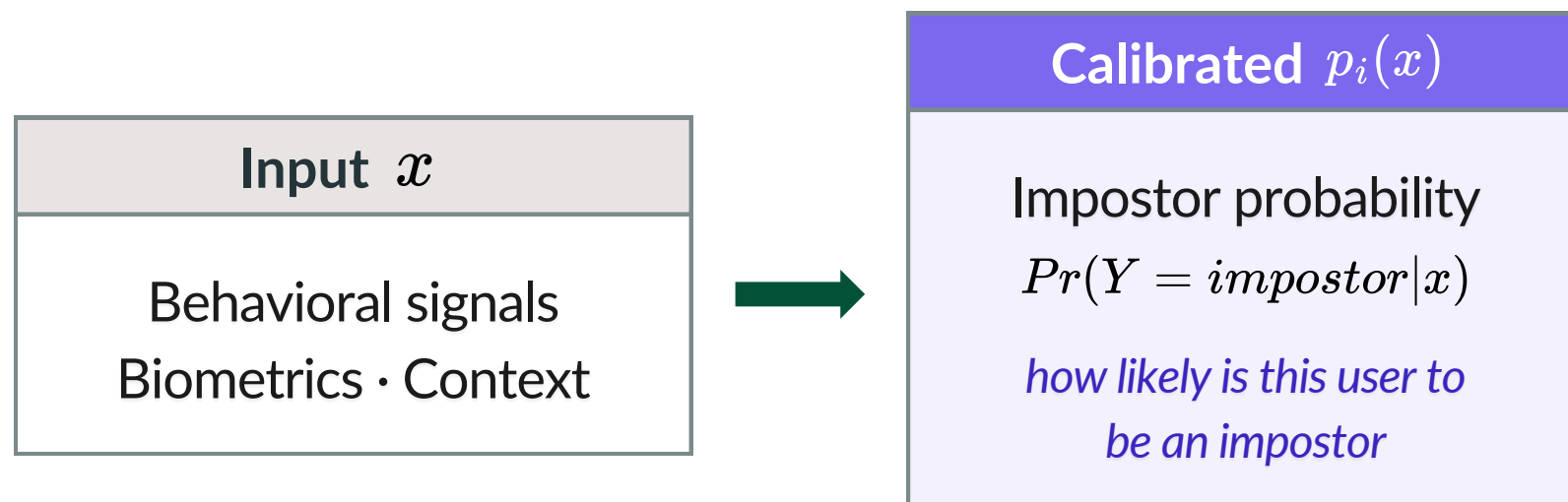
Reframing as a Decision Problem

Rather than asking whether a user passes a threshold, the RCM asks: **what is the least costly action given what we know?**

Input x
Behavioral signals Biometrics · Context

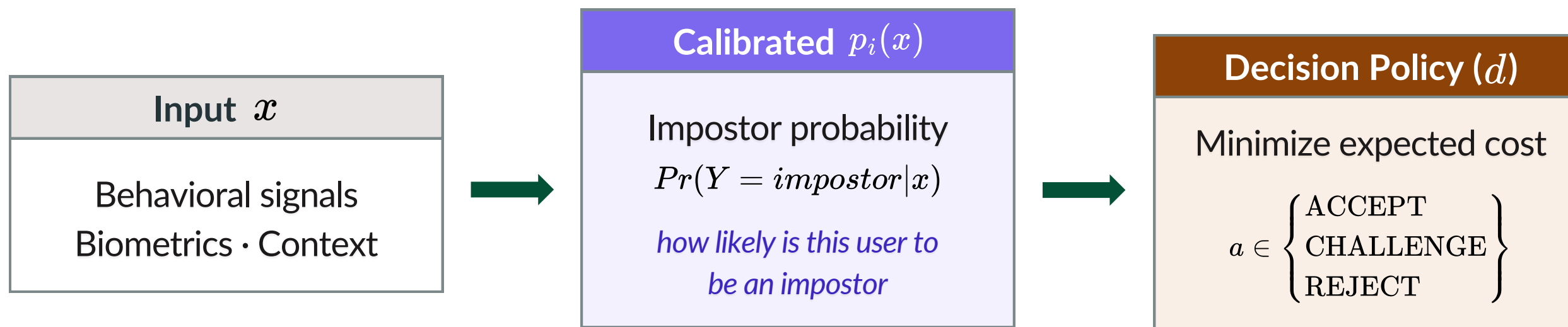
Reframing as a Decision Problem

Rather than asking whether a user passes a threshold, the RCM asks: **what is the least costly action given what we know?**



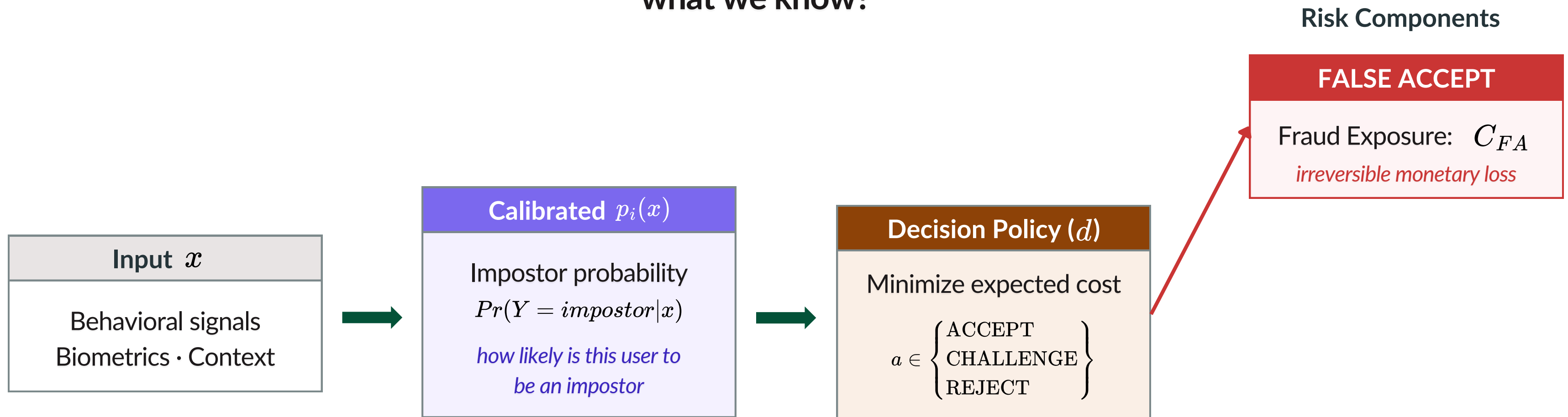
Reframing as a Decision Problem

Rather than asking whether a user passes a threshold, the RCM asks: **what is the least costly action given what we know?**



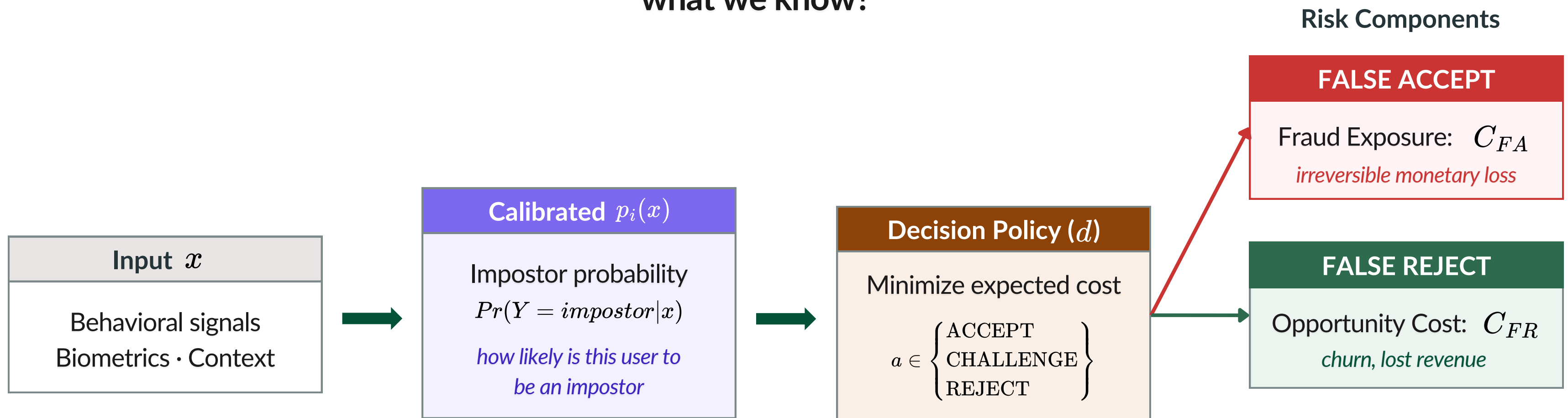
Reframing as a Decision Problem

Rather than asking whether a user passes a threshold, the RCM asks: **what is the least costly action given what we know?**



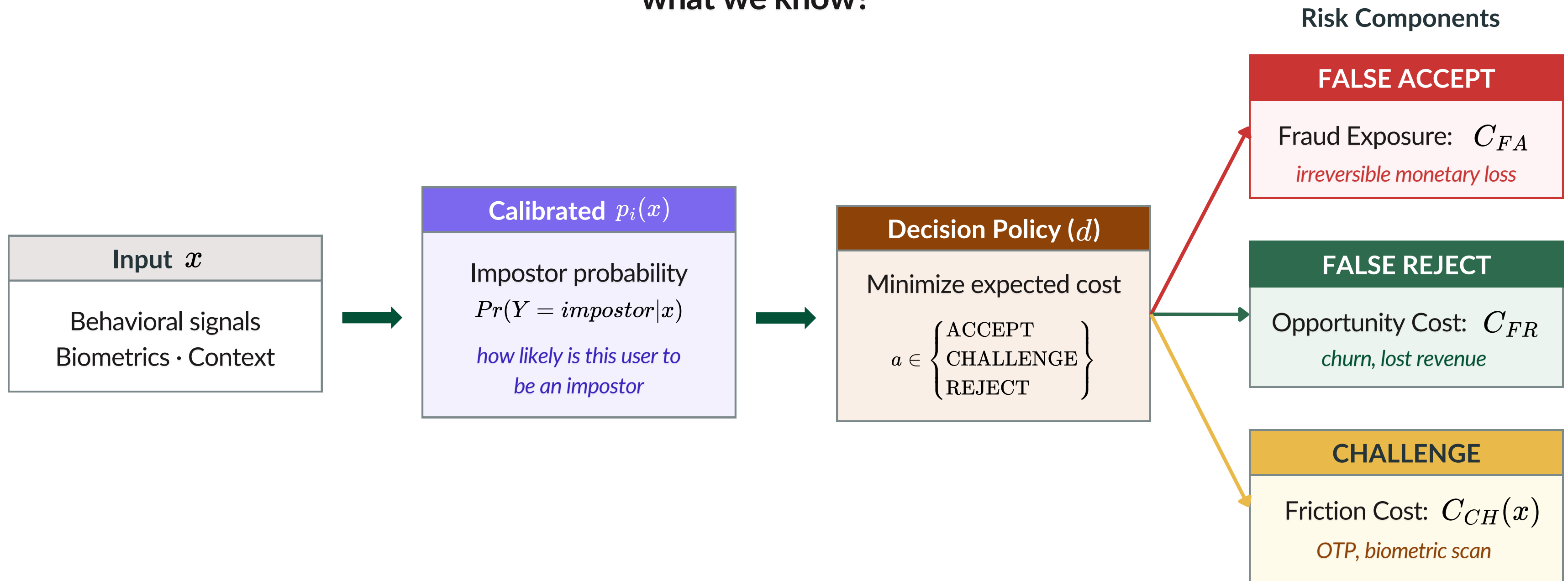
Reframing as a Decision Problem

Rather than asking whether a user passes a threshold, the RCM asks: **what is the least costly action given what we know?**



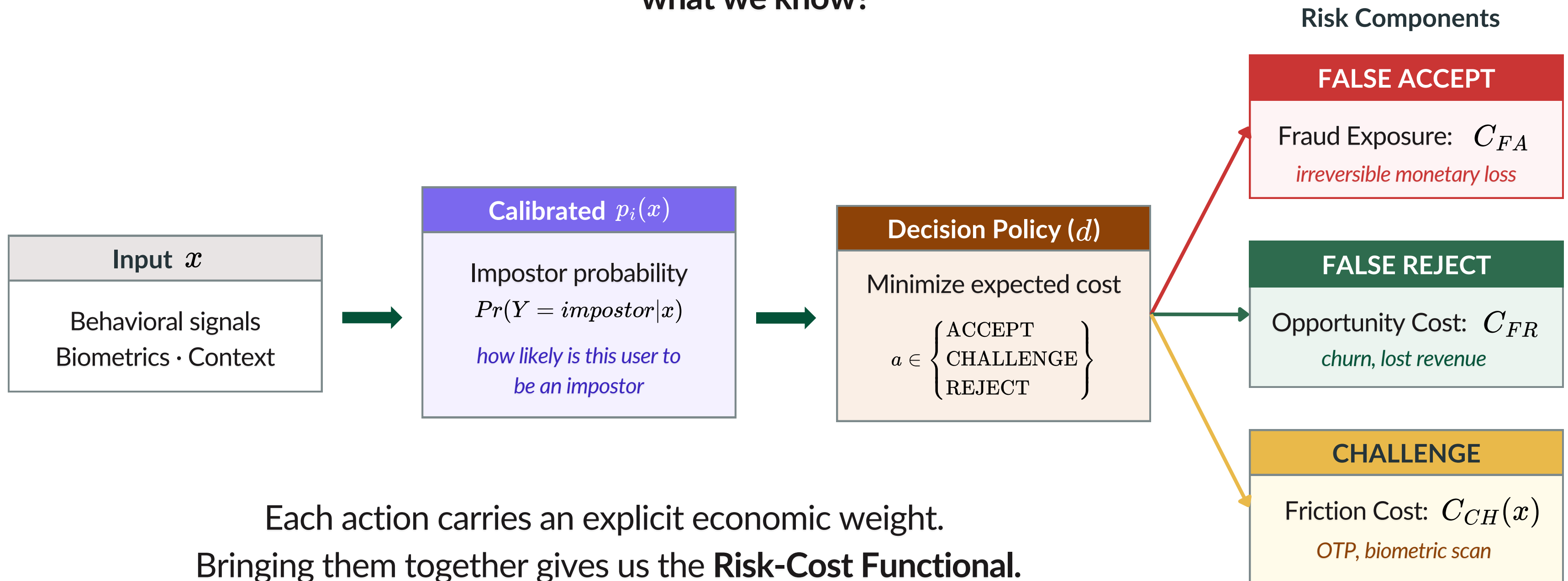
Reframing as a Decision Problem

Rather than asking whether a user passes a threshold, the RCM asks: **what is the least costly action given what we know?**



Reframing as a Decision Problem

Rather than asking whether a user passes a threshold, the RCM asks: **what is the least costly action given what we know?**



The Risk-Cost Functional

$$R(d) = c_{FA} \cdot FAR(d) + c_{FR} \cdot FRR(d) + c_{CH} \cdot CHR(d) + \lambda \cdot Leakage(d)$$

The total cost of a policy d : fraud loss, opportunity cost, challenge friction, and privacy exposure, all in the same units

The Risk-Cost Functional

$$R(d) = c_{FA} \cdot FAR(d) + c_{FR} \cdot FRR(d) + c_{CH} \cdot CHR(d) + \lambda \cdot Leakage(d)$$

The total cost of a policy d : fraud loss, opportunity cost, challenge friction, and privacy exposure, all in the same units

$$c_{FA} \cdot FAR(d)$$

FAR

False Acceptance Rate

Fraction of impostor
attempts wrongly accepted

c_{FA}

Expected monetary loss
per false accept

Largest cost in finance

The Risk-Cost Functional

$$R(d) = c_{FA} \cdot FAR(d) + c_{FR} \cdot FRR(d) + c_{CH} \cdot CHR(d) + \lambda \cdot Leakage(d)$$

The total cost of a policy d : fraud loss, opportunity cost, challenge friction, and privacy exposure, all in the same units

$$c_{FA} \cdot FAR(d)$$

FAR

False Acceptance Rate

Fraction of impostor
attempts wrongly accepted

c_{FA}

Expected monetary loss
per false accept

Largest cost in finance

$$c_{FR} \cdot FRR(d)$$

FRR

False Rejection Rate

Fraction of legitimate users
wrongly turned away

c_{FR}

Opportunity cost per false
reject: churn, lost revenue

Real but recoverable

The Risk-Cost Functional

$$R(d) = c_{FA} \cdot FAR(d) + c_{FR} \cdot FRR(d) + c_{CH} \cdot CHR(d) + \lambda \cdot Leakage(d)$$

The total cost of a policy d : fraud loss, opportunity cost, challenge friction, and privacy exposure, all in the same units

$$c_{FA} \cdot FAR(d)$$

FAR

False Acceptance Rate

Fraction of impostor
attempts wrongly accepted

c_{FA}

Expected monetary loss
per false accept

Largest cost in finance

$$c_{FR} \cdot FRR(d)$$

FRR

False Rejection Rate

Fraction of legitimate users
wrongly turned away

c_{FR}

Opportunity cost per false
reject: churn, lost revenue

Real but recoverable

$$c_{CH} \cdot CHR(d)$$

CHR

Challenge Rate

Fraction of attempts that
trigger a step-up challenge

c_{CH}(x)

User friction cost of the
challenge: OTP, biometric scan

Context-dependent

The Risk-Cost Functional

$$R(d) = c_{FA} \cdot FAR(d) + c_{FR} \cdot FRR(d) + c_{CH} \cdot CHR(d) + \lambda \cdot Leakage(d)$$

The total cost of a policy d : fraud loss, opportunity cost, challenge friction, and privacy exposure, all in the same units

$$c_{FA} \cdot FAR(d)$$

FAR

False Acceptance Rate

Fraction of impostor
attempts wrongly accepted

c_{FA}

Expected monetary loss
per false accept

Largest cost in finance

$$c_{FR} \cdot FRR(d)$$

FRR

False Rejection Rate

Fraction of legitimate users
wrongly turned away

c_{FR}

Opportunity cost per false
reject: churn, lost revenue

Real but recoverable

$$c_{CH} \cdot CHR(d)$$

CHR

Challenge Rate

Fraction of attempts that
trigger a step-up challenge

c_{CH}(x)

User friction cost of the
challenge: OTP, biometric scan

Context-dependent

$$\lambda \cdot Leakage(d)$$

Leakage(d)

Privacy or regulatory exposure

PII attributes exposed
during a step-up

λ Shadow price of privacy

Converts exposure into the
same cost units as the others

*Embeds compliance in the
objective*

Please refer to our paper for more details

Now that we understand what our RCM Model does, our paper discusses various associated concepts of RCM like Tail Risk, Conditional Value-at-Risk and Challenge Trigger Conditions.



Theory to Application

What adversaries actually do?

Probe the system to infer decision thresholds

Adversaries send many attempts to infer the decision threshold, then craft inputs that barely pass.

credential stuffing • phishing • replay attacks

Adapt across repeated interactions

Small low-value frauds each session, below the detection threshold, aggregate into substantial loss.

the policy catches up only after damage is done

Exploit distributional drift

User behavior shifts over time. A policy trained on past data fails silently as the distribution changes.

nominal policy fails under shifted inputs

Sequential Policy Optimization

At each authentication attempt, the policy runs the same five-step loop; adapting after every decision.

- 1
- 2
- 3
- 4
- 5

1. Observe features x_t

Compute impostor probability $p_i(x_t)$ and privacy increment $\Delta\epsilon_t$

2. Compute action risks

$R_{accept}, R_{reject}, R_{challenge}$ for this x_t - each weighted by c_{FA}, c_{FR}, c_{CH}

3. Choose the action minimising

$R(a|x_t) + \beta \cdot CVaR_\alpha$ -- balancing expected risk and tail exposure

4. Execute and log

Record realized loss L_t · update privacy budget $\epsilon_t \leftarrow \epsilon_{t-1} + \Delta\epsilon_t$

5. Adapt thresholds under drift

Policy updates continuously · privacy budget enforced · Repeat for $t = 1$ to T

Sequential Policy Optimization

At each authentication attempt, the policy runs the same five-step loop; adapting after every decision.

1
2
3
4
5

1. Observe features x_t

Compute impostor probability $p_i(x_t)$ and privacy increment $\Delta\epsilon_t$

2. Compute action risks

$R_{accept}, R_{reject}, R_{challenge}$ for this x_t - each weighted by c_{FA}, c_{FR}, c_{CH}

3. Choose the action minimising

$R(a|x_t) + \beta \cdot CVaR_\alpha$ -- balancing expected risk and tail exposure

4. Execute and log

Record realized loss L_t · update privacy budget $\epsilon_t \leftarrow \epsilon_{t-1} + \Delta\epsilon_t$

5. Adapt thresholds under drift

Policy updates continuously · privacy budget enforced · Repeat for $t = 1$ to T

What the loop achieves

- Thresholds adjust as attacker behavior shifts
- Privacy budget is enforced across all decisions
- Cumulative tail risk is tracked via CVaR
- Realized losses feed the next policy update
- Adversarial probing handled as a first-class concern

Limitations

No large-scale empirical validation on production financial systems

- The framework is formal and principled, but has not yet been tested on real financial workloads.

Cost parameters are difficult to estimate in practice

- c_{FA} , c_{FR} , and c_{CH} require domain-specific data that institutions may not have readily available.
- Proxy strategies exist, like A/B testing, CLV mapping, historical logs, but are not yet formally grounded.

Calibrated impostor probabilities assumed available

- The model assumes $p_i(x)$ can be reliably estimated. In practice, calibration requires careful validation.

Leakage quantification varies by institution and regulatory context

- Measuring privacy exposure consistently across different compliance frameworks remains an open challenge.

The RCM provides the foundation. Empirical grounding and formal estimation methods are the next steps.

Implications

For Practitioners

- Compliance alone is not a sufficient design goal
- Evaluate systems against explicit cost functions
- Monitor cumulative and tail-risk exposure over time

How to estimate cost parameters in practice

- *A/B test step-up flows $\rightarrow$ map abandonment rate to CLV gives c_{CH} empirically without domain-specific data*
- *Historical auth logs $\rightarrow$ derive $p(x)$, the challenge success probability*
- *Compliance risk matrices $\rightarrow$ bound $Leakage(d)$*

Implications

For Researchers

- Integrate cost-sensitive objectives into evaluations
- Treat sequential dynamics as first-class concerns
- FAR/FRR/EER are incomplete without cost mapping

The Methodological Argument

- *Future evaluation protocols should embed cost-sensitive and sequential reasoning directly, rather than treating them as secondary concerns*
- *A benchmark that ignores c_{FA} cannot tell you whether a system is safe in a financial setting*

Thank You. Questions are Welcome!



Data Agency and
Security (DAS) Lab



Learn more about our paper



Learn more about our lab



Supriya Khadka



Stay Connected!